

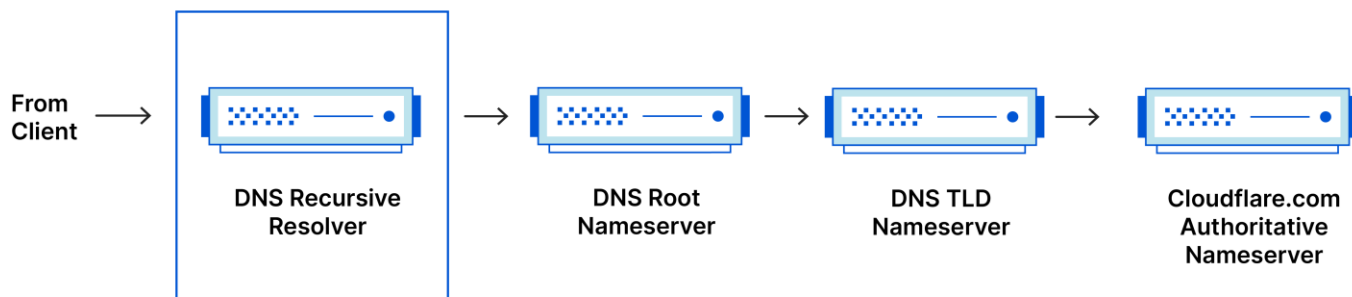
Introdução

O que é e como funciona o DNS

- ✓ Lista “telefónica” que relaciona nomes de domínio com os endereços IP;
- ✓ Baseado em servidores:
 - **DNS recursive resolver.** Servidor responsável por receber os pedidos dos clientes e reencaminhar os mesmos.
 - **DNS root *name servers*:** Primeiro passo na resolução de nomes. Num exemplo como ipp.pt, irá conter o endereço IP de todos os servidores do IPP.
 - **DNS top level domain server:** próximo passo, o que no nosso caso, terá os endereços PT
 - **DNS Authoritative nameserver.** Contem o IP específico para o nome, é o último passo;

Proteção por DNS

DNS Record Request Sequence



✓ Passos utilizados na resolução de nomes:

- Um utilizador pede www.ipp.pt, o pedido vai para o **DNS recursive resolver**.
- O **DNS recursive resolver** pergunta ao **DNS root nameserver**;
- O **DNS root nameserver** responde ao **DNS recursive resolver** com o endereço do **DNS Top Level Domain server**;

Proteção por DNS

- O **DNS recursive resolver** realiza o pedido ao **DNS Top Level Domain server**;
- O **DNS Top Level Domain server** responde com o endereço do **DNS Authoritative nameserver**;
- O **DNS recursive resolver** realiza o pedido ao **DNS Authoritative nameserver**;
- ✓ Se o **DNS recursive resolver** tiver, localmente, o endereço desejado não realiza as perguntas acima descritas;
- ✓ Se o cliente tiver, localmente, o endereço desejado não realiza a pergunta ao **DNS recursive resolver**
- ✓ O **DNS recursive resolver** tem, tipicamente, o mesmo IP da gateway.
- ✓ O **DNS recursive resolver** pode contactar um outro **DNS recursive resolver**.
 - Cliente 192.168.1.3/24 (sem correspondência no host file) contacta o **DNS recursive resolver** 192.168.1.1/24. UDP porta 53;

Proteção por DNS

- 192.168.1.1/24 (LAN), 203.24.53.16/20 (WAN) contacta o **DNS recursive resolver** 203.24.53.1/20. UDP porta 53

Block lists por DNS

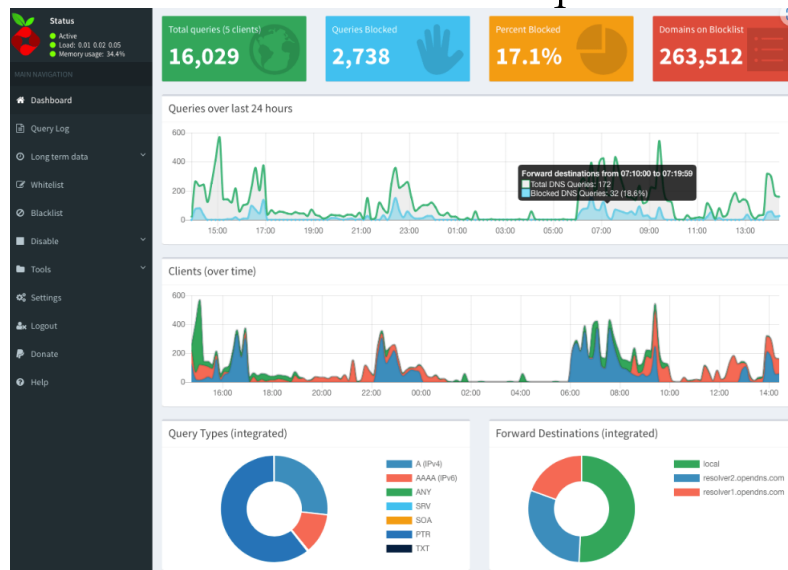
- ✓ Utilização das características acima enunciadas caso o **DNS recursive resolver** e/ou o cliente já tiverem a correspondência Nome<-> IP;
 - Se o cliente tiver uma lista de par Nome <-> IP (host file) e o nome estiver na lista, o cliente não realiza o pedido.
 - Se o **DNS recursive resolver** tiver uma lista de par Nome <-> IP não realiza a pergunta ao **DNS recursive resolver** seguinte;
- ✓ Proteção no cliente: editar o host file e colocar a entrada:
 - 127.0.0.1 grande_site_de_hacking.com. Todos os pedidos ao site grande_site_de_hacking.com são redirecionados para 127.0.0.1

Proteção por DNS

- Não editar manualmente o host file mas utilizar listas já pré preparadas como a mvps hosts e programas que atualizam automaticamente a hosts file como o hostman

✓ Proteção na rede:

- Colocar como **DNS recursive resolver** da gateway um **DNS recursive resolver** que contenha em si mesmo as listas de bloqueio. O exemplo



mais utilizado é o Pi-hole

Proteção por DNS

- Apontar o **DNS recursive resolver da gateway** para um **DNS recursive resolver** que contenha as listas de bloqueio: Quad-9: 9.9.9.9, cloudflare: 1.1.1.1, etc

✓ Vantagens:

- Simples de implementar;
- Proteção efetiva desde que as listas sejam mantidas;

✓ Desvantagens

- Necessário manter listas;
- Não temos muito controlo sobre o que é ou não cortado;
- Diminuição de QOS se forem misturadas listas de proteção com listas de anúncios;

Proteção por DNS

Obrigar todos os pedidos a passar pelo **DNS recursive resolver** da gateway

- ✓ Garantir que todos os pedidos DNS passam pela nossa gateway e não utilizam **DNS recursive resolver** “estranhos” como o 8.8.8.8
- ✓ Implementar uma regra de forwarding para o porto 53, protocolo UDP: Todos os pedidos DNS são enviados para o **DNS recursive resolver**
 - Interface: LAN; Protocol: TCP/UDP; Destination / Invert: Checked; Destination: LAN address; Destination Port: DNS; Redirect target IP: 127.0.0.1; Redirect target port: DNS; NAT reflection: Disable

Utilizar pedidos DNS encriptado e não DNS “normal”

- ✓ DNS over TLS (DoT): Os pedidos de DNS são encriptados por TLS e utilizam o porto 853. Realizados a nível do router

Proteção por DNS

- ✓ DNS over HTTPS (DoH): Os pedidos de DNS são encriptados por TLS e utilizam o porto 443. Realizados a nível do cliente
- ✓ Vantagens e desvantagens do DoH sobre DoT
 - O DoH permite “esconder” pedidos DNS no tráfego HTTPS
 - O DoT permite a implementação de políticas globais de segurança;

Garantir a segurança dos servidores DNS

- ✓ Ataques mais frequentes:
 - **DNS spoofing**: Introdução de dados na cache do **DNS recursive resolver** de forma a resolver nomes para **rogue** IP's;
 - **DNS tunneling**: Criação de um túnel que redireciona os pedidos DNS
 - **DNS hijacking**: Os pedidos a um servidor DNS são redirecionados para outro servidor. (por alteração do IP do servidor DNS);

Proteção por DNS

- **DoS**: Denial of service dos servidores DNS.
 - **NXDOMAIN**, flood attack.
 - **Random subdomain**, pedidos para domínios não existentes.
 - **Lock-up**, são criados DNS servers em que as respostas são muito lentas.
 - **Botnet-based CPE**, são utilizados centenas de routers de ISP
- ✓ Para dar resposta a algumas destas preocupações (exceto DoS e SNI), foi criado o DNSSEC (DNS Security Extensions)
 - A informação trocada entre servidores DNS é assinada digitalmente
 - A assinatura é hierárquica e em todos os níveis
 - A assinatura em todos os níveis termina no root zone em que seres humanos verificam a legitimidade do servidor

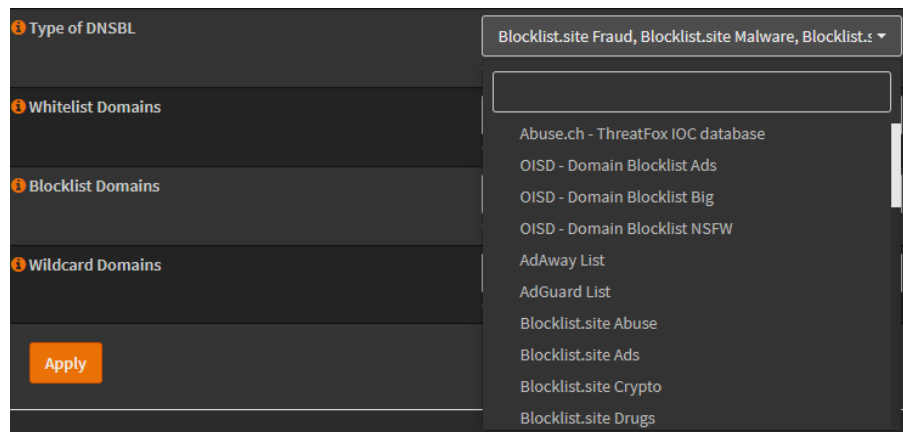
Proteção por DNS

- ✓ Para dar resposta aos DoS, a solução é implementação de *load balancing* com servidores primários e secundários ou a colocação de uma firewall de proteção para DoS.

Como implementar num caso concreto:

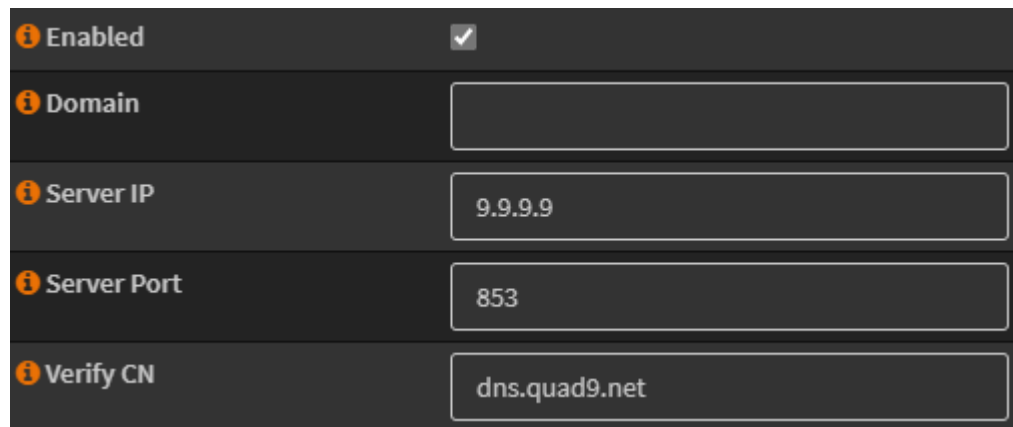
- ✓ Utilizar ou não listas privadas: Pi-hole versus 9.9.9.9 versus listas no próprio servidor para bloquear por blacklist
- ✓ A solução depende do pacote utilizado para implementar o DNS resolver. Ubound, bind, etc. Nem todos os pacotes permitem todos os níveis de segurança.
- ✓ Um caso concreto: Ubound recursive DNS
 - o black list escolher as pretendidas:

Proteção por DNS



The screenshot shows a configuration interface for DNSBL (Domain Name System Block List). On the left, there are four sections: 'Type of DNSBL', 'Whitelist Domains', 'Blocklist Domains', and 'Wildcard Domains'. The 'Type of DNSBL' section is active, showing a dropdown menu with the following options: 'Blocklist.site Fraud, Blocklist.site Malware, Blocklist.s...', 'Abuse.ch - ThreatFox IOC database', 'OISD - Domain Blocklist Ads', 'OISD - Domain Blocklist Big', 'OISD - Domain Blocklist NSFW', 'AdAway List', 'AdGuard List', 'Blocklist.site Abuse', 'Blocklist.site Ads', 'Blocklist.site Crypto', and 'Blocklist.site Drugs'. An 'Apply' button is visible at the bottom left of the configuration area.

- Escolher sempre DNS sobre TLS em que o **DNS recursive resolver** seguinte é de confiança



The screenshot shows a configuration interface for DNS. It contains five fields: 'Enabled' (checked), 'Domain' (empty), 'Server IP' (9.9.9.9), 'Server Port' (853), and 'Verify CN' (dns.quad9.net).

Field	Value
Enabled	☒
Domain	
Server IP	9.9.9.9
Server Port	853
Verify CN	dns.quad9.net

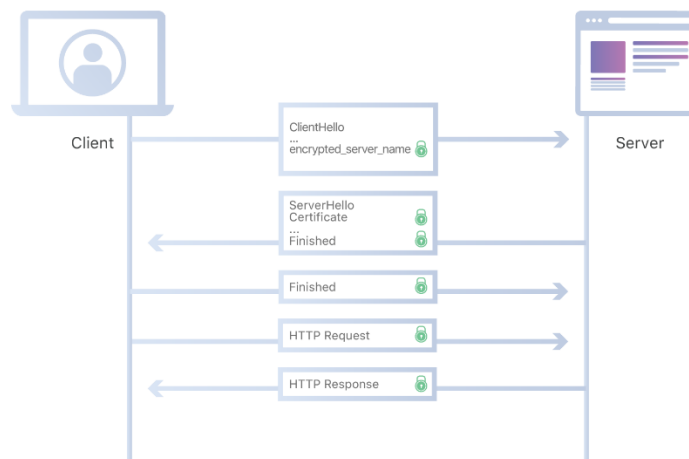
Proteção por DNS

O problema do SNI (Server Name Indication):

- ✓ A falha do TLS: No TLS tradicional, o nome do site (SNI) é enviado em texto limpo.
 - A SNI faz parte do handshake TLS (Hello). O cliente verifica o certificado TLS do servidor web. O servidor deve enviar o certificado como parte de sua resposta.
 - Muitos servidores web hospedam mais de um site, e cada site tem seu próprio certificado TLS.
 - A SNI resolve o problema o cliente indica qual site. No entanto, nenhuma criptografia pode ser realizada até que o handshake TLS seja concluído com sucesso usando a SNI.
- ✓ Recorrendo ao SNI é possível verificar qual o site que foi contactado.

Proteção por DNS

- ✓ A solução ESNI (*Encrypted Server Name Indication*)
 - Servidor web adiciona uma chave pública à entrada DNS
 - O cliente utiliza a chave pública para encriptar o SNI no *hello* do TLS
 - O servidor descripta com a chave privada e continua o *handshake* TLS.

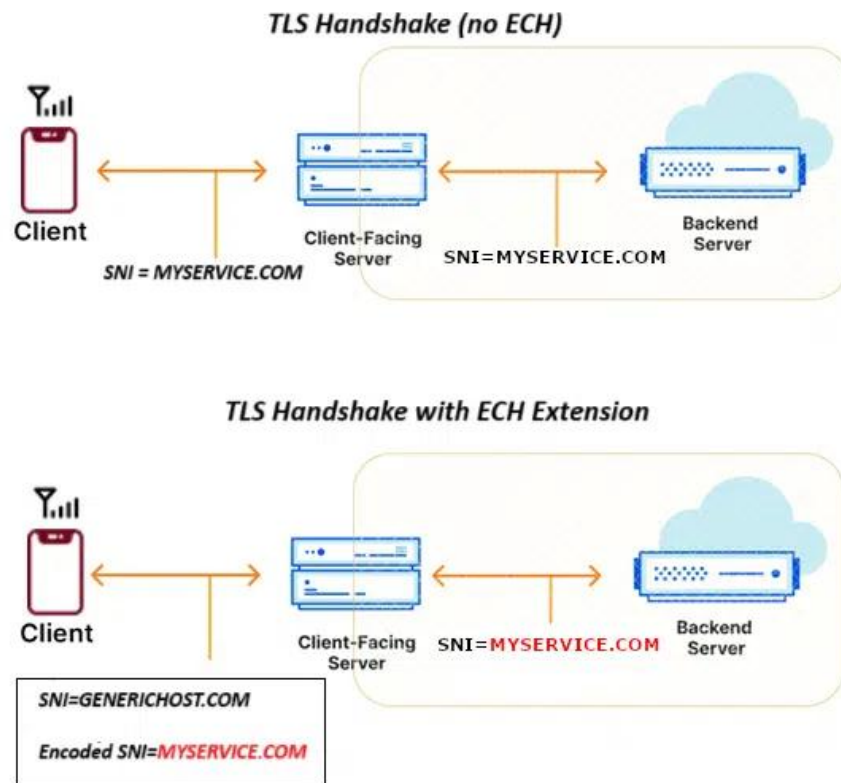


<https://blog.cloudflare.com/encrypted-sni/>

Proteção por DNS

- ✓ A solução ECH (*Encrypted Client Hello*)
 - Não faz parte do TLS 1.3 mas de uma extensão
 - Passam a existir duas mensagens Hello.
 - ClientHelloOuter. Não encriptada para manter a compatibilidade com sites que não suportam ECH.
 - ClientHelloInner. Encriptada
 - Necessário DOH ou DOT para recolher a chave pública.
 - Site sem suporte ECH e site com suporte ECH

Proteção por DNS



<https://www.enea.com/solutions/traffic-management/encrypted-client-hello-ech-tls-1-3/>